Tools and Methods Used in Cybercrime

Acknowledgement

- **Cyber Security** by Nina Godbole, Sunit Belapure, Wiley India

Introduction

- How criminals plan cyberoffenses?
- How mobile technology plays an important role to launch cyberattacks?
- Now, focus upon different forms of attacks through which attackers target the computer systems

Tools and Techniques of Attack

- Scareware:
  - Comprises of **several classes of scam software** with malicious payloads
  - Sold to consumers via certain unethical marketing practices
  - Selling approach uses social engineering to cause shock, anxiety or the perception of threat
- Malvertising:
  - It is Malicious Advertising – **malware + advertising**
  - Focused on installation of unwanted or outright malicious software

Tools and Techniques of Attack

- Clickjacking:
  - **Tricking netizens** into revealing confidential information and/or taking control of their system while **clicking on seemingly innocuous web pages.**
  - **Embedded code and/or script which is executed without netizen's knowledge**
- Ransomware:
  - Malware that **holds a computer system**, or the data it contains, **hostage against its user by demanding a ransom for its restoration**.
  - It may disable an essential system service or lock the display at system start-up and **encrypt** some of the user's personal file

Stages of an attack on network

1. **Initial covering:** two steps
   1. Reconnaissance- social networking websites, public websites
   2. Uncovers information on company's internal network like domain, IP address ranges etc.
2. **Network probe:**
   1. Ping sweep- seek out potential targets
   2. Port scanning
3. **Crossing the line toward electronic crime (E-crime):**
   1. Commits computer crime by exploiting possible holes on the target system
      - Exploits include vulnerabilities in **common gateway interface (CGI) scripts, buffer overflow holes, default login accounts**
      - Once able to access user account without many privileges, the further exploits to **get an administrator access**

Stages of an attack on network

4. **Capturing the network:**
   - attackers attempts to own the network
   - uses tools to remove any evidence of the attack
   - Install trojan horses, provide backdoor entry
5. **Grab the data:**
   - attacker has captured the network
   - steal confidential data, customer Credit Card information, deface web pages …
6. **Covering the attack:**
   - extend misuse of the attack without being detected
   - start a fresh reconnaissance to a related target system
   - continue use of resources
   - remove evidence of hacking

- Attacker takes care to hide his / her Identity from the first step itself.

Various tools and Methods used for the attack

- Proxy severs and Anonymizers
- Phishing
- Password cracking
- Keyloggers and spywares
- Virus and Worms
- Trojan horses and Backdoors
- Steganography
- SQL injection
- DoS and DDoS attack tools
- Buffer overflow

Proxy Servers and Anonymizers

- Proxy server is computer on a network which acts as an **intermediary for connections** with other computers on that network
- Attacker **first connects to proxy server and then establishes a connection with the target system**
- This enables an attacker **to surf the Web anonymously** and/or hide the attack
- Proxy server can allow an attacker to **hide ID**

Proxy Servers and Anonymizers

- **Purpose** of proxy server:
  - Keep the system behind the curtain
  - Speed up access to resource
  - Specialized proxy servers are used to **filter unwanted content** such as advertisement
  - Proxy server can be used as **IP address multiplexer to enable to connect number of computers** on the Internet, whenever one has only one IP address

Proxy Servers and Anonymizers

- An anonymizer or an anonymous proxy is a tool that **attempts to make activity on the Internet untraceable**
- It accesses the Internet user's behalf, **protecting personal information** by hiding the source computer's identifying information

Phishing

- **Fake E-Mail** using other reputed companies or individual's identity
- Messages are
  - Stealing personal and financial data
  - Infect systems with viruses
  - A method of online ID theft
- People associate phishing with E-Mail message that **spoof or mimic banks, credit card companies or other business such as Amazon and eBay**

How Phishing works?

- **Planning:** decide the target & determine how to get E- Mail address
- **Setup:** create methods for delivering the message & to collect the data about the target
- **Attack:** sends a phony message that appears to be from a reputable source
- **Collection:** record the information of victims entering into web pages or pop-up window
- **Identify theft and fraud:** use information that they have gathered to make illegal purchases and commit fraud

Password Cracking

- **Password Cracking** is the process of **recovering passwords** from data that have been stored in or transmitted by a computer system.
- A common approach (**brute-force attack**) is to **try guesses** repeatedly for the password and check them against an available cryptographic hash of the password.

The purpose of password cracking

- **Help a user** to recover a forgotten password
- As a **preventive measure** by System Administrators **to check** for easily crackable passwords
- To **gain unauthorized access** to a system

Manual Password Cracking Steps

1. Find a **valid** user account
2. Create a **list** of possible passwords
3. **Rank** the passwords from high probability to low
4. **Key-in each** password
5. **Try again until** a successful password is found

Examples of guessable passwords

- Blank
- Words like “passcode” ,”password”, “admin”
- Series of letters “QWERTY”
- User’s name or login name
- Name of the user’s friend/relative/pet
- User’s birth place, DOB
- Vehicle number, office number, residence number or mobile number
- Name of celebrity
- Simple modification of one of the preceding, such as suffixing a digit, particularly 1 or reversing the order of letters

Password Cracking

- **Manual cracking:** Script file to **try each** password in **a list**
- Passwords are **stored in database**, and password verification data is **not stored in a clear text format**
- **One-way function** is applied to the password, and the resulting (**hashed password**) **value** is **stored**.

Categories of password cracking attacks:

- Online attacks
- Offline attacks
- Non-electronic attacks
  - Social engineering
  - Shoulder surfing
  - Dumpster diving

Online attacks

- An attacker may create a **script file** (automated program) to try each password **in a list**
- Most popular online attack;- **man-in-the-middle attack or bucket-brigade attack**
- Used to **obtain passwords for E-mail accounts** on public websites like gmail, yahoomail
- Also to get passwords **for financial websites**

Offline attacks

- Performed from a **location other than the target** where these passwords **reside** or are used
- **Require physical access** to the computer and **copying the password file** from the system onto removable media

Types of Password Cracking Attacks

- Dictionary attack
  - Attempts to **match all the words from the dictionary** to get the password
- Hybrid attack
  - **Substitutes numbers and symbols** to get the password
- Brute force attack
  - **Attempts all possible permutation – combination** of letters, numbers and special characters

Strong, Weak and Random Passwords

- Weak password
  - **Easily guessed**, short, common and a system default
  - Words in the dictionary
  - Proper names and words based on the username
  - Date of Birth, pet's name, spouses' name
- Strong password
  - **Long** enough, **random** or otherwise difficult to guess

Random Passwords

- **Mix** of upper and lower case letters, numbers and other symbols
  - **Difficulty in remembering** such passwords
- System – created random passwords **ensure no connection with that user**
- **Password aging:** users **change password** regularly

Guidelines for the Password Policies

- Password and user logon ID should be **unique** to each authorized user
- **Minimum eight** alphanumeric characters
- Computer – controlled lists of **prescribed password rules** and periodic testing
- **Shall not be shared, shall not be coded** into programs or noted down anywhere
- Shall be **changed every 30/45 days or less**

Guidelines for the Password Policies

- Account should be **frozen after five failed logon** attempts
- **Sessions should be suspended after 15 minutes** of inactivity and require the password to be re-entered
- Successful logons should **display the date & time of the last logon & logoff**
- Logon IDs and passwords should be **suspended after a specified period of non-use**
- For high-risk systems, **after excessive violations**, the system should generate an alarm and be able to **simulate a continuing session (with dummy data)** for the failed user

Keyloggers and Spywares

- Keystroke logging, often referred to as keylogging or keyboard capturing, is the action of **noting (or logging) the keys struck** on a keyboard, typically in a covert manner so that the **person** using the keyboard **is unaware** that their actions are being monitored.
- It has uses in the study of human–computer interaction.
- There are numerous keylogging methods, ranging from **hardware and software-based approaches to acoustic analysis**.

Software Keyloggers

- Software programs installed on the computer systems, usually located **between the OS and the keyboard hardware** and every keystroke is recorded.
- Installed by **Trojans or viruses**
- Usually consists of **two files DLL and EXE**, installed in the same directory
  - **DLL does all the recording of keystrokes**

Hardware Keyloggers

- installing a **hardware circuit between the keyboard and the computer** that logs keyboard stroke activity into a file or in the memory of the hardware device
- Target- **ATMs**

Acoustic Keylogging

- Acoustic keylogging **monitors the sound created by each individual keystroke** and uses the subtly different acoustic signature that each key emits to analyze and determine what the target computer's user is typing.

AntiKeylogger

- Antikeylogger is a tool that can **detect the keylogger installed** on the computer system and also **can remove** the tool
- Advantages of using Antikeylogger
  - Can detect installation of keylogger
  - Does not require regular updates
  - Prevents Internet banking frauds
  - Prevents ID theft
  - Secures E-Mail and instant messaging / chatting

Spywares

- Spyware is a type of **malware** that is installed on computer which **collects information about users** without their knowledge
- Hidden from the user, **secretly monitors** the user
- **Collects personal information** about the victim
  - Internet surfing habbits / patterns and websites visited
- **Redirect** Internet surfing
- **Change** computer settings
- **Install anti – Spyware software**

Virus and Worms

- Computer virus is a program that can "**infect**" legitimate programs by modifying them to include a possibly "evolved" copy of itself.
- Viruses **spread themselves**, without the knowledge or permission of the users
- **Contains malicious instructions**
- A virus can **start on event driven effects, time driven effects, or can occur random**.

Virus and Worms

- Viruses **can take some actions**:
  - Display a message to prompt an action into which may set the virus
  - Delete files inside the system
  - Scramble data on hard disk
  - Cause erratic screen behavior
  - Halt the PC
  - Replicate themselves to propagate further harm

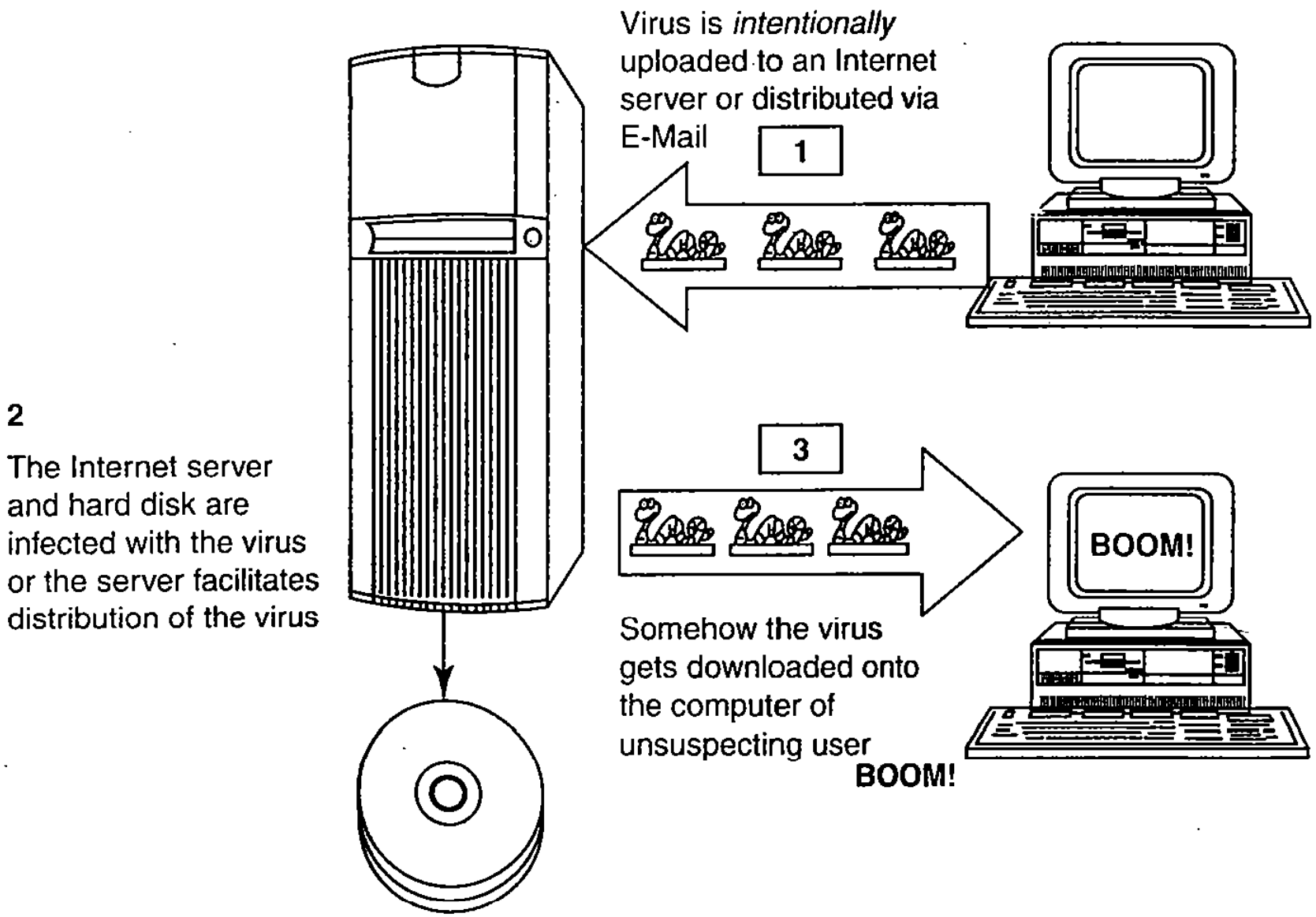


Figure 4.1 | Virus spreads through the Internet.

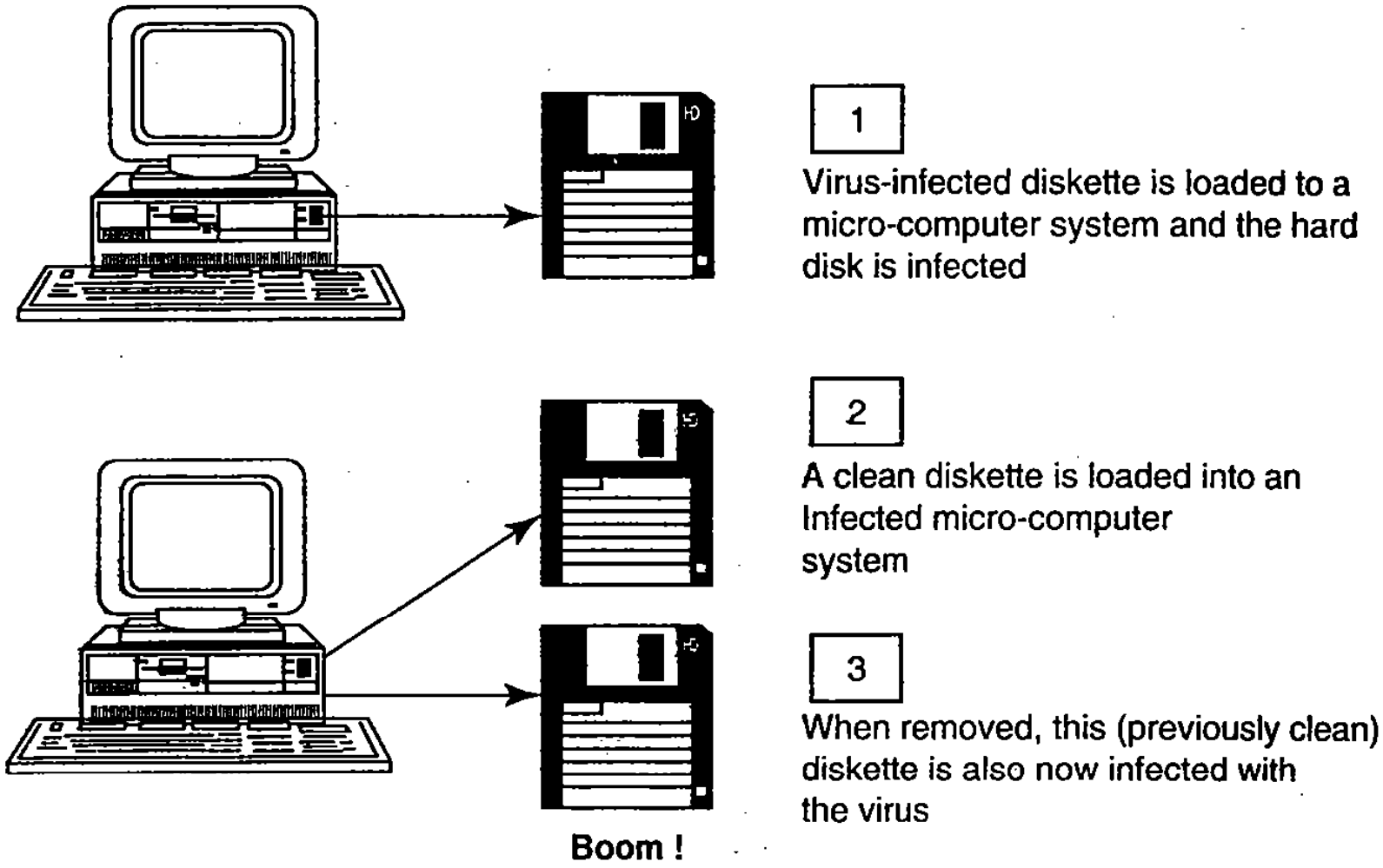


Figure 4.2 | Virus spreads through stand-alone system.

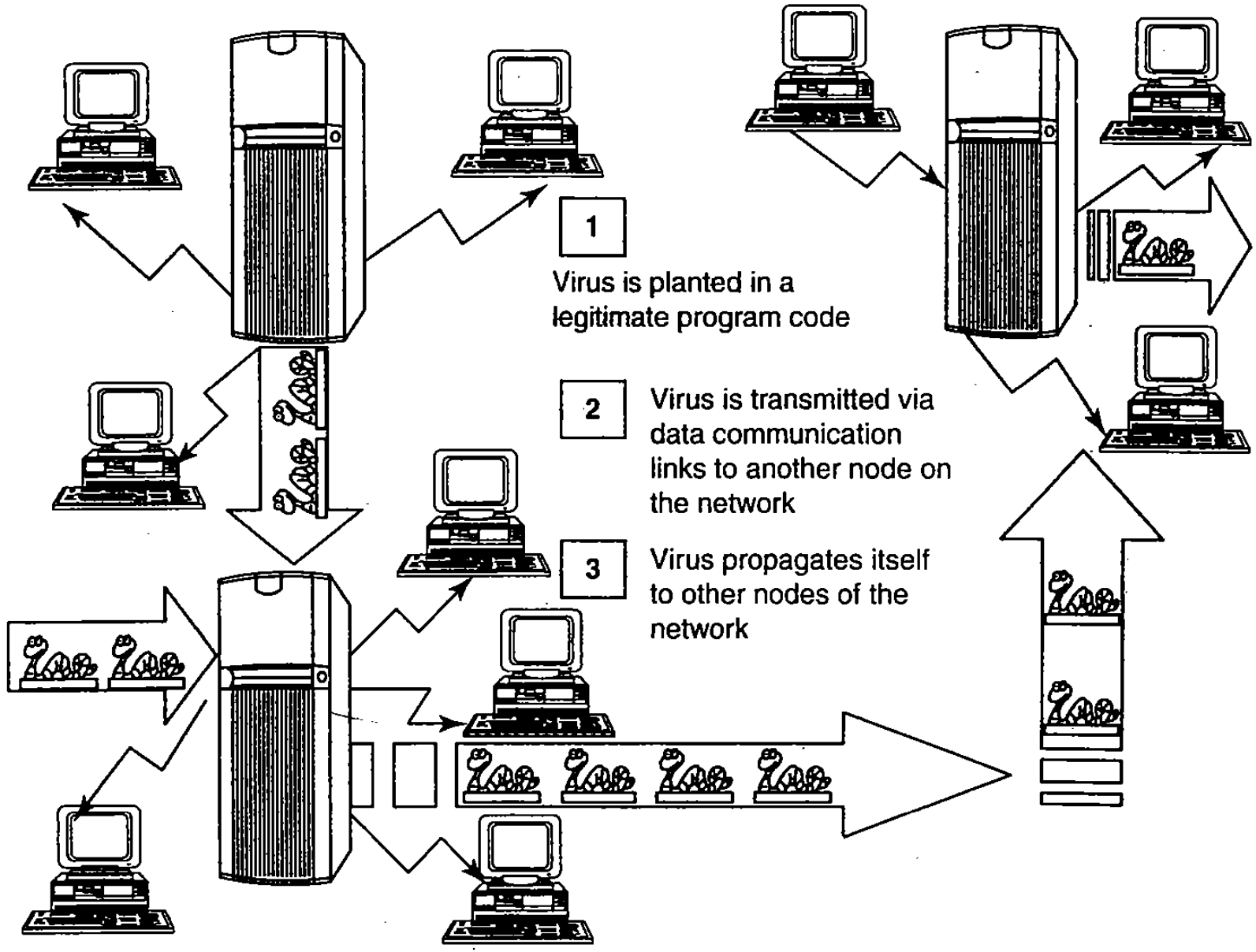


Figure 4.3 | Virus spreads through local networks.

Virus and Worms

- Virus has the ability to **copy itself and infect the system**
- **Malware, Adware and Spyware** programs **do not have reproductive ability**
- True virus can only **spread from one system to another when its host is taken to the target computer**
- A **worm spreads itself automatically** to other computers through networks by exploiting security vulnerabilities
- **Trojan is a code / program** that appears to be **harmless but hides malicious functions**

Table 4.7 | Difference between computer virus and worm

Sr. No.	*Facet*	*Virus*	*Worm*
1	Different types	Stealth virus, self-modified virus, encryption with variable key virus, polymorphic code virus, metamorphic code virus	E-Mail worms, instant messaging worms, Internet worms, IRC worms, file-sharing networks worms
2	Spread mode	Needs a host program to spread	Self, without user intervention
3	What is it?	A computer virus is a software program that can copy itself and infect the data or information, without the users' knowledge. However, to spread to another computer, it needs a host program that carries the virus	A computer worm is a software program, self-replicating in nature, which spreads through a network. It can send copies through the network with or without user intervention
4	Inception	The creeper virus was considered as the first known virus. It was spread through ARPANET in the early 1970s. It spreads through the TENEX OS and uses connected modem to dial out to a remote computer and infect it.	The name worm originated from The Shockwave Rider, a science fiction novel published in 1975 by John Brunner. Later researchers John F Shock and Jon A Hupp at Xerox PARC published a paper in 1982, *The Worm Programs* and after that the name was adopted
5	Prevalence	Over 100,000 known computer viruses have been there though not all have attacked computers (till 2005)	Prevalence for virus is very high as against moderate prevalence for a worm.

Types of Viruses

- Categorized **based on attacks** on various element of the system
- **Boot sector viruses:**
  - Infects the storage media on which OS is stored and which is used to start the computer system
  - Spread to other systems when shared infected disks & pirated software(s) are used
- **Program viruses:**
  - Active when program file (usually with extensions .bin, .com, .exe, .ovl, .drv) is executed
  - Makes copy of itself

Types of Viruses

- **Multipartite Viruses:**
  - **Hybrid of a boot sector and program viruses**
- **Stealth viruses:**
  - **disguise** and/or masks itself
  - **Antivirus S/W also cannot detect**
  - **Alter its file size and hide in the computer memory** to remain in the system undetected
  - 1st computer virus named as Brain

Types of Viruses

- **Polymorphic viruses:**
  - Like “chameleon” that **changes its virus signature** (i.e., binary pattern) **every time it spread through the system** (i.e., multiplies & infect a new file)
  - Polymorphic **generators are routines** that can be **linked with the existing viruses**
  - **Generators are not viruses** but **purpose to hide actual viruses** under the cloak of polymorphism

Types of Viruses

- **Macroviruses:**
  - Documents with **MACRO enabled** gets infected
- **Active X and Java control:**
  - Web browsers have settings about Active X and Java control
  - Allow certain **functions to work** – such as enabling or disabling pop-ups, downloading files and sound

Virus and Worms

- **Worm is a self-replicating malware** computer program
- **Uses computer network** to send copies of itself to other nodes **without any user intervention**
- **Worm does not need to attach itself** to an existing program
- Worms cause **some harm to network**, whereas **viruses always corrupt or modify files** on a targeted computer

Virus and Worms

- **Definition** of Computer virus / worms:
  - A virus attacks **specific file types**
  - A virus **manipulates** a program to **execute tasks unintentionally**
  - An infected program **produces more viruses**
  - An infected program may **run without error** for a long time
  - Viruses can **modify themselves** and may possibly **escape detection**

Trojan Horses and Backdoors

- **Trojan horse is a program** in which malicious or harmful code is contained inside apparently harmless programming or data in such a way that **it can get control and cause harm**
- Get into system from number of ways, including **web browser, via E-Mail, or with S/W download from the Internet**

Trojan Horses and Backdoors

- Trojans **do not replicate** themselves but they can be equally destructive
- **Examples of threats by Trojans:**
  - Erase, overwrite or corrupt data on computer
  - Help to spread other malware
  - Deactivate or interfere with antivirus and firewall
  - Allow to remote access to your computer
  - Upload and download files without user knowledge
  - Gather E-Mail address and use them for spam
  - Log keystrokes to steal info such as password or credit card no.
  - Copy fake links to false websites, display porno sites, play sounds/videos and display images
  - Slow down , restart or shutdown the system
  - Reinstall themselves after being disable
  - Disable task manager or control panel

Backdoor

- It means of **access to a computer program that bypass security mechanisms**
- Programmer use it **for troubleshooting**
- Attackers often use backdoors that they detect or **install themselves as part of an exploit**
- **Works in background** and hides from user
- Most **dangerous parasite**, as it allows a malicious person to perform any possible action
- Programmer sometimes leave such backdoor in their software **for diagnostic and troubleshooting** purpose. **Attacker** discover these undocumented features and **use them**

What a Backdoor Does?

- Allow an attacker to **create, delete, rename, copy or edit any file; change any system setting, alter window registry; run, control and terminate application; install arbitrary software**
- To **control computer hardware devices**, modify related setting, **shutdown or restart** a computer without asking for user permission
- **Steals** sensitive personal information, **logs** user activity, **tracks** web browsing habits
- **Record keystrokes**
- **Sends all gathered data to predefined E-Mail address**

What a Backdoor Does?

- **Infects** files, corrupts installed app & damage entire system
- **Distributes** infected files to remote computers and **perform attack** against hacker-defined remote hosts
- **Installed hidden FTP server** that can be used by malicious person
- **Degrade Internet connection** speed and overall system performance
- **Provide no uninstall feature** and hides processes, files and other objects to complicate its removal as much as possible

Examples of Backdoor Trojan

- Back orifice:
  - Enable user to control a computer running the Microsoft Windows OS from remote location
- Bifrost:
  - Infect Windows 95 through Vista
- SAP backdoors
  - infects SAP business objects
- Onapsis Bizploit
  - Onapsis Bizploit is an ERP penetration testing framework to assist security professionals in the discovery, exploration, vulnerability assessment and exploitation phases of specialized SAP security assessment

How to Protect from Trojan Horses and Backdoors

- Stay away from **suspect websites/ web links**
- **Surf** on the web **cautiously**
- **Install antivirus/ Trojan remover software**

Steganography

- Greek word that means “Sheltered writing”
- Comes from 2 Greek words:
  - Steganos means “covered”
  - Graphein means “to write” or “concealed writing”
- The art and science of **hiding information so that it does not even appear to exist**
- Other names: data hiding, information hiding, digital watermarking

Steganography

- Stagenography can be used to **make a digital watermark to detect illegal copying** of digital images
- Digital watermarking is the process of possibly **irreversibly embedding information** into a digital signal

Difference between Steganography and Cryptography

- **Cryptography** is the study of **hiding information**, while **Steganography deals with composing** hidden messages so that only the sender and the receiver know that the message even exists.
- In **Steganography**, only the **sender and the receiver know** the existence of the message, whereas in **cryptography** the existence of the encrypted message is **visible to the world** but content is obscured
- **Cryptographic** methods try to **protect the content** of a message, while Steganography uses methods that would **hide both the message as well as the content**.
- By **combining Steganography and Cryptography** one can achieve better security.

Steganography

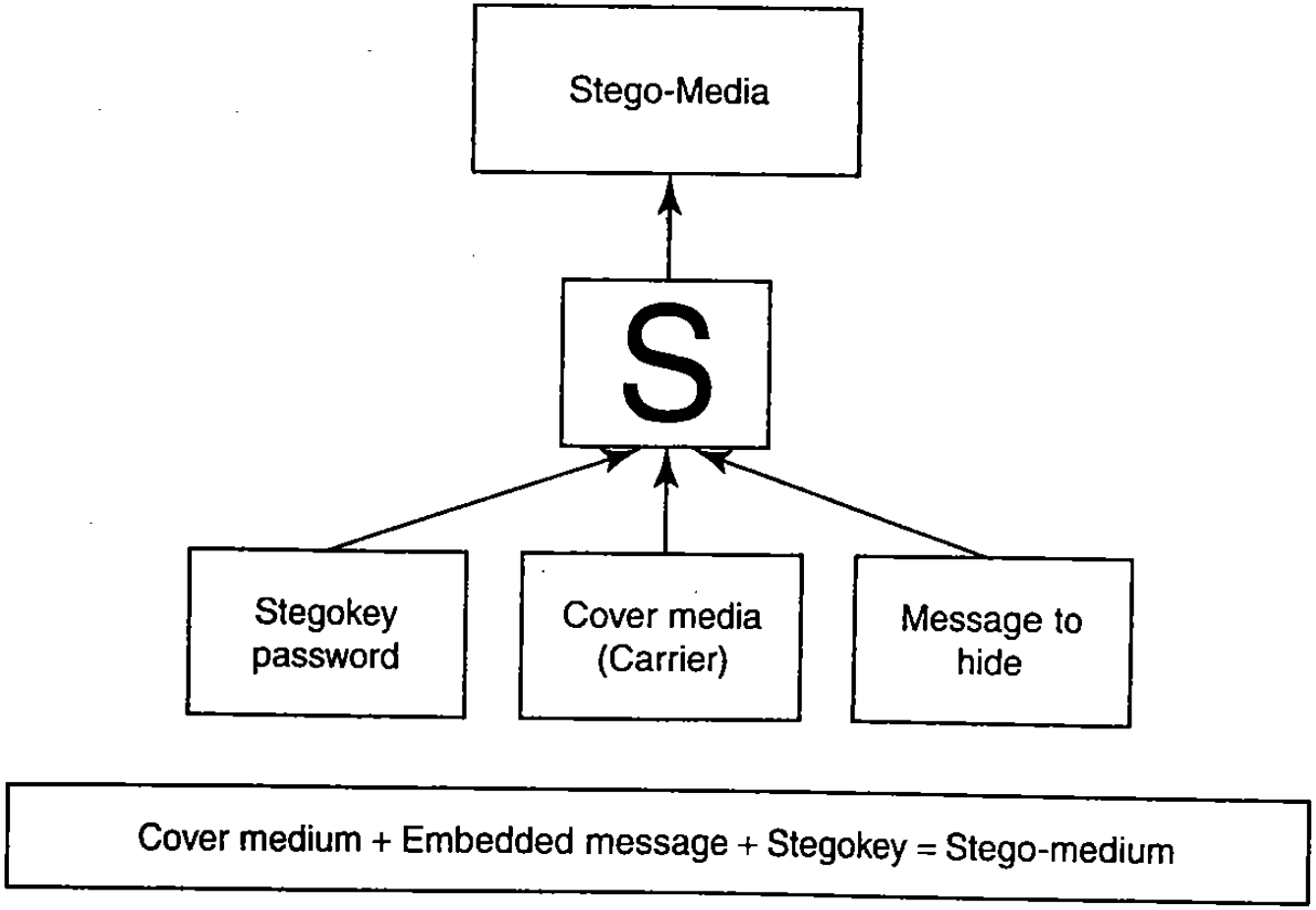


Figure 4.4 | How steganography works.
Source: http://www.cosc.iup.edu/sezekiel/Seminar/steg.ppt#452,15,Steganography%20of%20today's%20talk (11 May 10).

Steganalysis

- Steganalysis is the art and science of **detecting messages that are hidden** in images, audio/video files using steganography
- The **goal** of steganalysis is to **identify suspected packages**, determine whether or not they have a **payload encoded into** them, and, if possible, **recover that payload**.

DoS and DDoS attacks

- A Denial – of – service attack (DoS attack) or Distributed Denial – of – service attack (DDoS attack) is an attempt to make a **computer resource unavailable** to its intended users
- DoS attack:
  - Attacker **floods the Bandwidth** of the victim's N/W or fills his E-Mail box with **Spam mail** depriving him of the services he is entitled to access or provide
  - Attacker typically **target** sites or services hosted on **high-profile web servers** such as banks, credit card payment gateways, mobile phone networks and even root name servers

DoS Attack

- **Buffer overflow** technique is employed to commit such kind of criminal attack known as **Spoofing**.
- **Spoofing** refers to the **creation of IP packets with a forged source IP address** with the purpose of concealing the ID of the sender or impersonating another computing system
- The attacker **spoofs the IP address and floods the network** of the victim **with repeated requests**
- As the IP address is fake, the victim machine **keeps waiting for response from the attacker's machine** for each request
- This **consumes the Bandwidth** of the N/W which then fails to server the legitimate responses and ultimately breaks down

What DoS Attack Does?

- Goal of DoS is not to gain unauthorized access to systems or data, but **to prevents intended users of a service from using it**.
- **Activity done by DoS**
  - Flood a network with traffic
  - Disrupt connection between two systems
  - Prevent a particular individual from accessing service
  - Disrupt service to a specific system or person

Classification of DoS Attacks

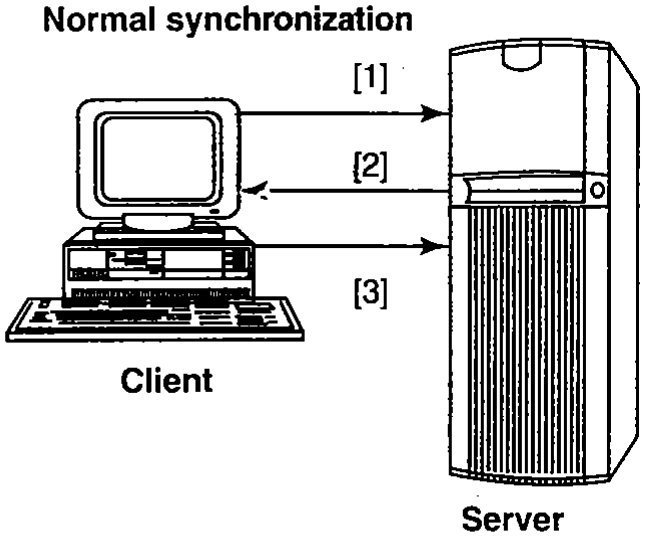
- Bandwidth attacks
  - Consuming all the bandwidth of site
- Logic attack
  - Exploit vulnerabilities in network software such as web server or TCP/IP stack
- Protocol attacks
  - Exploit specific feature or implementation bug of some protocol installed at victim's system to consume excess amount of its resources
- Unintentional DoS attack
  - Website ends up denied due to sudden enormous spike in popularity

Types or Levels of DoS Attacks

1. Flood attack: (Ping flood)
   - Attacker **sending number of ping** packets, using "ping" command, which result into more traffic than victim can handle
   - This requires the attacker to have faster network connection than the victim
   - **Prevention is difficult**
2. Ping of death attack:
   - Sends **oversized ICMP packets**
   - **Receiving this packet will crash, freeze or reboot system**

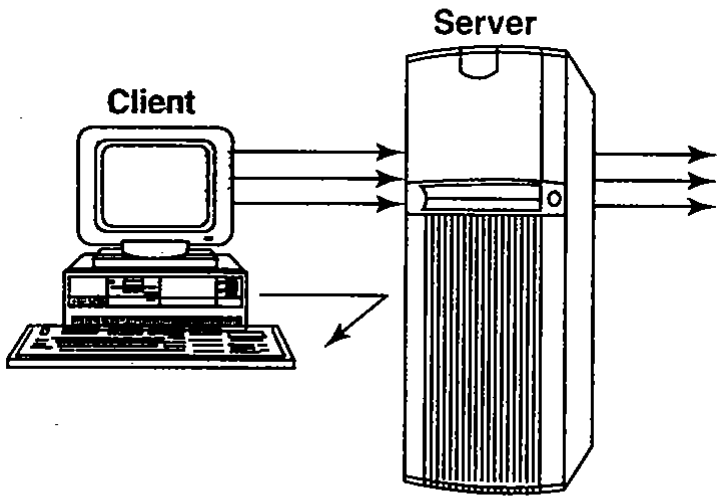
Types or Levels of DoS Attacks

3. SYN attack: (TCP SYN flooding)



3-way Handshake

- Client sends synchronize (syn) pkt to web server
- Server sends synchronize acknowledgment (syn-ack)
- Client replies with an acknowledgment pkt, the connect is established



Chaotic Handshake

- Client sends multiple synchronize (syn) pkts to web server – all with bad addresses
- Server sends synchronize acknowledgments to in correct addresses leaving half open connections and flooded queue
- Legitimate user is denied access because queue is full and additional connections cannot be accepted

Figure 4.5 | Denial-of-service (DoS) attack.

Types or Levels of DoS Attacks

4. Teardrop attack:
   - Attack where **fragmented packets are forged to overlap each other** when the receiving host tries to **reassemble them**
   - **IP's packet fragmentation algorithm** is used to **send corrupted packets** to **confuse the victim** and **may hang the system**
   - Windows 3.1x, 95 and NT , Linux versions 2.0.32, 2.1.63 are vulnerable to this attack

Types or Levels of DoS Attacks

5. Smurf attack:
   - **Generating significant computer network traffic** on victim network, using floods via spoofed broadcast ping message
   - Attack consists of a **host sending ICMP echo request** (ping) to a network broadcast address
   - Every host receive this packet & send back ICMP echo response
   - Internet relay chat (IRC)servers are primarily victim of smurf attack

Types or Levels of DoS Attacks

6. Nuke:
   - An old DoS attack against computer n/w s consisting of **fragmented or otherwise invalid ICMP packets** sent to target
   - Achieved by using a modified ping utility to repeatedly send this corrupt data, thus **slowing down the affected computer** until it comes to complete stop
   - Eg. WinNuke, which is exploited the **vulnerability in the NetBIOS handler in windows 95**. A string of out-of- band data was sent to TCP port 139 of victim's machine, causing it to lock up and display Blue Screen Of Death (BSOD)

Tools used to Launch DoS Attack

- Jolt2: attack against window based machine- consume 100% of CPU time on processing of illegal packets
- Nemesy: generates random packets of spoofed source IP
- Targa: used to run 8 different DoS attacks
- Crazy Pinger: send large packets of ICMP
- SomeTrouble: remote flooder and bomber – developed in Delphi

Blended Threat

- It is a more sophisticated attack that **bundles** some of the worst aspects of viruses, worms, Trojan Horses and Malicious code into **one single threat**
- **Use server & Internet vulnerabilities** to initiate, transmit and thereafter spread attack
- Characteristics:
  - Cause harm to the infected system or network
  - Propagate using multiple methods as attack may come from multiple point
  - Exploit vulnerability

Blended Threat

- Serve **multiple attacks in one payload**
- To use multiple mode of transport, including E-mail, IRC and file-sharing networks
- Rather than a specific attack on predetermined ".exe" files, it could do **multiple malicious acts**, such as modify your ".exe" files, HTML files and registry keys

Permanent Denial–of–Service (PDoS) Attack

- Damages a system so badly that it **requires replacement or reinstallation of hardware**
- DDoS attack **sabotage a service or website**
- PDoS is a pure hardware sabotage (e.g. Routers, printers or other networking hardware)
- **Replace a device's firmware** with a modified, corrupted or defective firmware image
- **PhlashDance** is a tool created by Rich Smith who detected and demonstrated PDoS

DDoS Attacks

- Attacker **use your computer to attack another computer**
- By taking advantage of security vulnerabilities or weaknesses, an attacker could **take control of your computer**, then **force your computer to send huge amounts of data to a website or send spam to particular E-Mail addresses**
- The attack is "**distributed**" because the attacker is **using multiple computers** to launch the DoS attack
- Large number of **zombie systems** are synchronized to attack aparticular system. Zombie systems are called "**secondary victims**" and **main target is called "primary victim"**

How to Protect from DoS / DDoS Attacks

- Implement router **filters**
- If such filters are available in your system, **install patches** to guard against TCP SYN flooding
- **Disable** any unused or inessential n/w service
- **Enable quota** systems on your OS if they are available
- Observe your **system performance** and establish baselines for ordinary activity
- Routinely examine your **physical security**

How to Protect from DoS / DDoS Attacks

- Use tools to **detect changes in configuration** info or other files
- Invest and maintain "**hot spares**" – machines that can be placed into service quickly if a similar machine is disabled
- Invest in **redundant and fault-tolerant** network configuration
- Establish and maintain **regular backup schedules** and policies
- Establish and maintain appropriate **password policies**

SQL Injection

- It is a **code injection** technique that exploits a security vulnerability occurring in **Database (DB) layer** of application
- Also known as **SQL insertion attacks**
- **Target the SQL servers**
- Objective : "to **obtain the information** while accessing a **DB table** that may contain personal information"
- **Malicious code is inserted into a web form field** or the website's code to make a system execute a command shell or other arbitrary commands

Steps for SQL Injection Attack

- Attacker looks for the WebPages that allow **submitting data**, that is login page, search or **feedback page** etc. Also looks HTML commands such as **POST and GET** by checking the site's source code
- Checks the source code of HTML and looks for **"FORM" tag**.

Steps for SQL Injection Attack

- Inputs a **single quote** under the textbox provided on the webpage to accept the username and password. This checks whether the **user-input variable is sanitized or interpreted** literally by the server. If the **response is an error message** such as “a” = “a” then the **website is found to be susceptible to an SQL injection attack**
- **Uses SQL commands such as SELECT or INSERT**

Steps for SQL Injection Attack

- Examples of variable field text the attacker uses on a webpage to test SQL vulnerabilities:
  - Blah’ or 1=1—
  - Login:blah’ or 1=1—
  - Password:blah’ or 1=1—
  - http://search/index.asp?id=blah’ or 1=1—
  - The **double dashes** near the end of the command tell SQL to **ignore the rest of the command as a comment**

Steps for SQL Injection attack

- **Step 1: Finding Vulnerable Website:**
  - find the Vulnerable websites (hackable websites) using Google Dork list.
  - google dork is searching for vulnerable websites using the google searching tricks
  - use "**inurl:**" command for finding the vulnerable websites.
- Some Examples:
  inurl:index.php?id=
  inurl:gallery.php?id=
  inurl:article.php?id=
  inurl:pageid=
- **How to use?**
  copy one of the above command and paste in the google search engine box. Hit enter.
  You can get list of web sites.
  We have to **visit the websites one by one** for checking the vulnerability.

Steps for SQL Injection attack

- **Step 2: Checking the Vulnerability:**
  - Now we should check the vulnerability of websites.
  - In order to check the vulnerability, add the **single quotes(‘) at the end of the url** and hit enter.
- For eg:

  http://www.victimsite.com/index.php?id=2'
  - If the page remains in same page or showing that page not found or showing some other webpages, then it is not vulnerable.
  - If it **showing any errors** which is related to **SQL query**, then it is vulnerable.

Steps for SQL Injection attack

- **Step 3: Finding Number of columns:**
  - Now we have found the website is vulnerable.
  - Next step is to **find the number of columns in the table**.
    For that **replace the single quotes (‘) with “order by n” statement**
  - **Change the n from 1,2,3,4,,5,6,…n.** Until you get the error like “unknown column “.
- For eg:
  http://www.victimsite.com/index.php?id=2 order by 1
  http://www.victimsite.com/index.php?id=2 order by 2
  http://www.victimsite.com/index.php?id=2 order by 3
  http://www.victimsite.com/index.php?id=2 order by 4
  …..
  http://www.victimsite.com/index.php?id=2 order by 8 (error)

so now x=8 , The number of column is x-1 i.e, 7.

Steps for SQL Injection attack

- **Step 4: Displaying the Vulnerable columns:**
  - Using "**union select columns_sequence**" we can find the vulnerable part of the table. **Replace the "order by n"** with this statement.
  - And **change the id value to negative**
  - **Replace the columns_sequence with the number from 1 to x-1 (number of columns) separated with commas(,).**
- For eg:
  if the number of columns is 7 ,then the query is as follow:
  http://www.victimsite.com/index.php?id=-2 union select 1,2,3,4,5,6,7—

Blind SQL Injection

- It is **used when** a web application is vulnerable to SQL injection but **the results of the injection are not visible to the attacker**
- The **page with the vulnerability** may not be one that displays data but will **display differently** depending on the results of a logical statement injected into the legitimate SQL statement called for that page.
- This type of attack can become **time-intensive** because a new statement must be crafted for each bit recovered.
- There are several **tools that can automate these attacks** once the location of the vulnerability and the target information has been established

Using SQL injection, What attacker can?

- **Obtain some basic information** if the purpose of the attack is reconnaissance
  - To get directory listing
  - To ping an IP address
- May gain access to the DB by obtaining username & password
  - To get user listing: SELECT * FROM users WHERE name= "OR '1'='1'."
- Add new data to the DB
  - Execute INSERT command
- Modify data currently in the DB
  - Execute UPDATE command

How to Prevent SQL Injection Attacks

- Attack occur due to **poor websites administration and coding**
- **Steps to prevent SQL injection:**

1. **Input validation:**
   - **Replace all single quotes to two single quotes**
   - **Sanitize the input:** user inputs needs to be checked and cleaned of any characters or strings that could possibly be used maliciously
   - Numeric value should be checked
   - Keep all text boxes and form fields as short as possible to limit the length of user input

How to Prevent SQL Injection Attacks

2. Modify error reports

- SQL error should not be displayed to outside users

3. Other preventions

- SQL server 2000 never be used
- **Isolate DB server & web server**. Both should reside in different machine
- Extended stored procedures are not used or have unused triggers, stored procedures, user defined functions etc., then these should **moved to an isolated server**

Buffer Overflow

- Buffer overflow or buffer overrun, is an anomaly (irregularity) where **a process stores data in a buffer outside the memory** the programmer has set aside for it
- Extra data may **result in erratic program behavior**, including memory access errors, incorrect result, program termination, or a breach of system security
- It can be triggered by inputs that are designed to execute code or alter way the program operates
- Programming language associated with it including C, C++, which provide no **built- in protection** against accessing or overwriting data in any part of memory
- **Security attack on data integrity**

Types of Buffer Overflow

- ***Stack- Based Buffer Overflow:***
  - occurs when a program writes to memory address on the program's call stack **outside the intended data structure** - usually fixed length buffer
  - Characteristic of stack based programming:
    - "Stack" is a memory space in which **automatic variables are allocated**
    - **Function parameters are allocated on stack** & are not automatically initialized by the system
    - Once function has completed its cycle, the **reference to the variable in the stack is removed**

Types of Buffer Overflow

- ***Stack- Based Buffer Overflow:***
  - The attacker may exploit stack-based buffer overflows to manipulate the program in various ways **by overwriting**:
    - **A local variable that is near the buffer in memory on the stack** to change the behavior of the program that may benefit the attacker
    - **Return address in a stack frame**. Once the function returns, execution will resume at the return address as specified by the attacker, usually input-filled buffer
    - A **function pointer, or execution handler**, which is subsequently executed
  - Factors that contribute to **overcome the exploits** are:
    - Null bytes in address
    - Variability in the location of shellcode
    - Differences between environments

Types of Buffer Overflow

- ***NOPs:***
  - No Operation (NOP) or No Operation Performed (NOOP)
  - It is an **assembly language instruction**/ command that effectively does nothing at all
  - NOP allows code to **execute when the exact value of the instruction pointer is indeterminate**
  - It helps to **know/locate the exact address of the buffer** by effectively increasing the size of the target stack buffer area
  - Attacker can increase the odds of findings the right memory address by **padding his/her code with NOP operation**.
  - To do this, much larger sections of the stack are **corrupted with NOOP** machine instruction
  - At the end of the attacker- supplied data, after the NOOP, an instruction is placed to perform a **relative jump to the top of buffer** where shellcode is located

Types of Buffer Overflow

- ***Heap Buffer Overflow:***
  - Occurs in the **heap data area** and may be introduced accidentally by an application programmer or it may result from a deliberate exploit

How to Minimize Buffer Overflow

- Assessment of secure code manually
  - Avoid vulnerable functions, such as strcpy(), strcat(), vsprintf() etc., which operate on **null-terminated strings and perform no bounds checking**
  - Validate input after scanf() function
- Disable stack execution
  - Code residing in stack cause segmentation violation
- Compiler tools
  - Offer **warnings on the use of unsafe constructs**, such as gets(), strcpy() etc.
- Dynamic run-time checks
  - **Safety code / tool being preloaded** before an application is executed
- Various tools are used to detect/defend buffer overflow: for eg. **StackGuard, ProPolice, LibSafe**

Attacks on Wireless Networks

- Wireless networks **extend the range** of traditional wired networks by using radio waves to transmit data to wireless-enabled devices.

Attacks on Wireless Networks

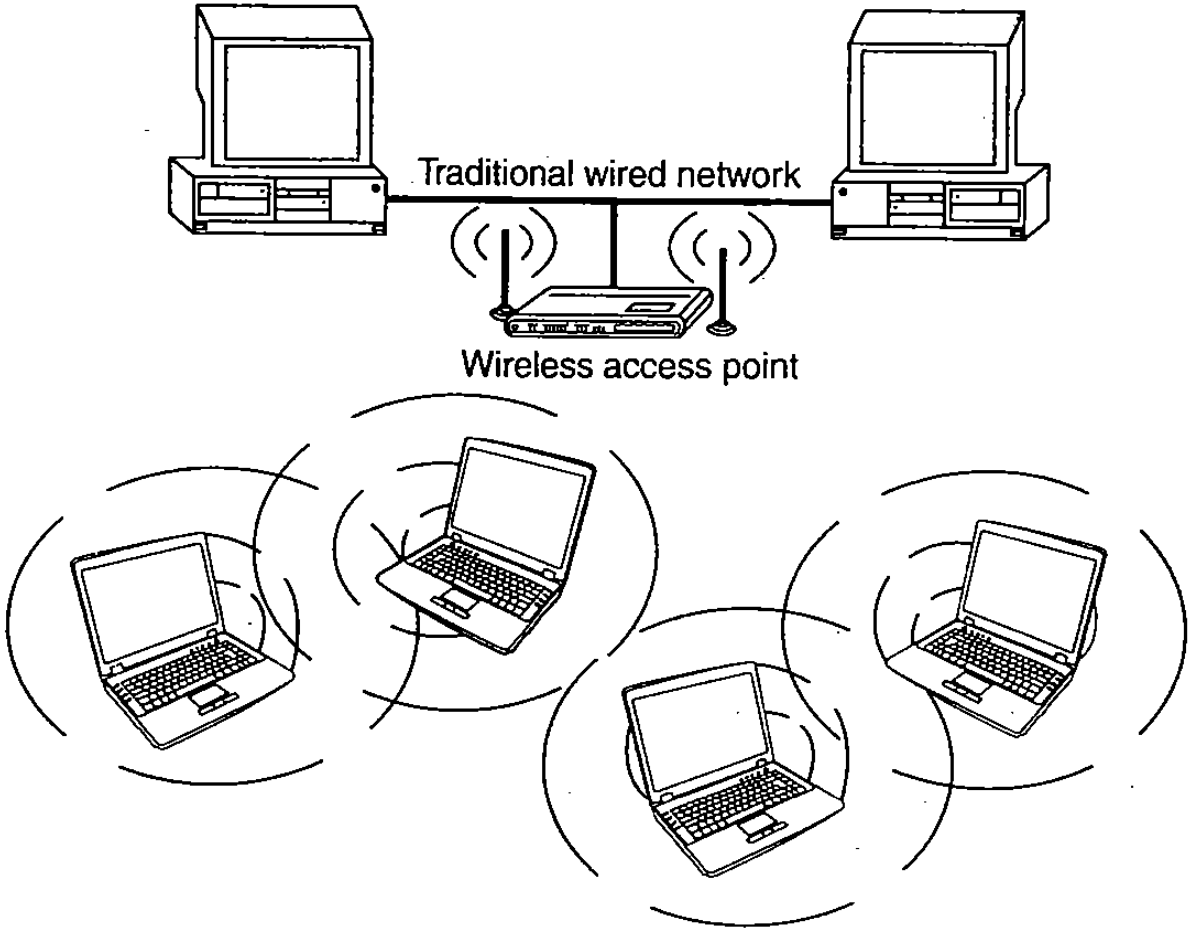


Figure 4.6 | Wireless networks.

Components of Wireless Network

802.11 networking standards:

- 802.11: provides 1 or 2 Mbps transmission in the 2.4 GHz using either FHSS or DSSS
- 802.11a: provides 54 Mbps transmission in the 5 GHz using OFDM
- 802.11b: provides 11 Mbps transmission in the 2.4 GHz
- 802.11g: provides 54 Mbps transmission in the 2.4 GHz using OFDM
- 802.11n: uses MIMO to improve speed and range

Components of Wireless Network

802.11 networking standards:

- 802.15: used for personal WLANs and covers a very short range. Used for Bluetooth Technology.
- 802.16: known as WiMax. Combines the benefit of broadband and wireless. Used for Wireless Metropolitan Networks.

Components of Wireless Network

Access Points (AP):

- Central transmitter and receiver of WLAN radio signals
- Laptops/PDAs get connected to AP, which in turn connected with the wired LAN

Wi-Fi hotspots:

- Offers Internet access over WLAN
- Free Wi-Fi hotspots
- Public Wi-Fi hotspots
- A “poisoned / rogue hotspot” is termed to be a free public hotspot set up by the cybercriminals, with the objective of sniffing the data sent by the user.

Components of Wireless Network

Service set identifier (SSID):

- It is the name of 802.11i WLAN and all wireless devices must use the same SSID to communicate with each other
- 32 characters long
- Turn OFF the broadcast of the SSID

Wired equivalence privacy (WEP):

- Security algorithm for IEEE 802.11i WLANs

Components of Wireless Network

Wi-Fi protected access (WPA and WPA2):

- Weakness in WEP resulted WPA
- WPA2 provides stronger encryption mechanism through Advanced Encryption Standard (AES)

Media access control (MAC):

- Unique identifier of each network interfaces
- MAC address filtering
- Attacker can spoof a MAC address

Traditional Techniques of Attacks on Wireless Networks

- In security breaches, **penetration of a wireless network** through unauthorized access termed as **wireless cracking**

Traditional Techniques of Attacks on Wireless Networks

- Sniffing
  - Passive scanning of wireless network
  - Detection of SSID
  - Collecting the MAC address
  - Collecting the frames to crack WEP
- Spoofing
  - Objective is to masquerade the identity by falsifying data and thereby gaining an illegitimate advantage
  - Attacker create new network with stronger wireless signal and copied SSID, there by computers automatically connect to the spoofed network
  - MAC address spoofing, IP Spoofing, Frame Spoofing
- DoS
- Man-in-the-middle attack
- Encryption cracking

Theft of Internet Hours and Wi-Fi-based Frauds and Misuses

- The **plug-and-play feature of router** exposes for an attack when the user visits a malicious webpage
- **Access to neighbor's wireless connection** without paying for it

How to Secure the Wireless Networks

- **Change the default settings** of all the equipments / components of wireless network
- **Enable WPA/WEP** encryption
- **Change the default SSID**
- **Enable MAC address filtering**
- **Disable remote login**
- **Disable SSID broadcast**
- Disable the features that are not used in AP
- Avoid providing the n/w a name which can be easily identified

How to Secure the Wireless Networks

- **Connect only to secured wireless n/w**
- **Upgrade router's firmware** periodically
- **Assign static IP address to devices**
- **Enable firewalls** on each computer & the router
- Position the router or AP safely
- Turn off the n/w during extended periods when not in use
- Periodic and regular monitor wireless n/w security